

CISM CERTIFICATION EXAM SIMULATOR

Practice Exam 14

Domain II - Information Security Risk Management

30 Questions	48 Minutes	Single Best Answer Format
-----------------	---------------	------------------------------

This publication contains original practice material designed for exam preparation. It does not reproduce confidential certification questions and is not affiliated with or endorsed by ISACA.

Instructions

- Allow approximately 48 minutes for this domain set.
- Select one best answer for every question.
- Record your selections before consulting the answer key.
- Review every explanation, including questions you answered correctly.

Questions

Question 1 (CISM4-028)

Which statement BEST describes risk appetite?

- A. The risk remaining after controls
- B. The maximum loss the organization can survive
- C. A specific control-performance threshold
- D. The risk an organization is willing to pursue or retain.

Question 2 (CISM4-029)

What is the MOST reliable basis for rating the impact of an information asset's unavailability?

- A. The asset's original purchase price alone
- B. The number of vulnerabilities on the asset
- C. Validated consequences to dependent business processes and objectives
- D. The technical team's preferred recovery tool

Question 3 (CISM4-030)

Scenario: A startup wants to guarantee losses from a new digital escrow service. The modeled worst plausible loss exceeds its available capital, even though executives have a high appetite for growth.

Which conclusion is MOST appropriate?

- A. High appetite makes the exposure acceptable
- B. The exposure exceeds risk capacity and requires redesign, limitation, or another viable response
- C. The security manager should increase the company's capital estimate
- D. The assessment should ignore worst plausible loss until an event occurs

Question 4 (CISM4-031)

Scenario: A water utility classifies a telemetry archive as low criticality because operators do not use it for real-time control. Investigation shows that regulatory release decisions depend on its integrity and that altered history could keep unsafe equipment in service.

What should drive the revised impact rating?

- A. The safety and regulatory consequences of corrupted historical data
- B. Its lack of real-time control functions
- C. The number of files stored
- D. The archive's storage cost

Question 5 (CISM4-032)

Scenario: A recruiting service approved for domestic applicant data will begin replicating records to a new overseas support center. The supplier says its technical controls are unchanged.

What should the information security manager do FIRST?

- A. Reassess jurisdiction, data flow, obligations, access, and business impact
- B. Retain the old rating because technical controls are unchanged
- C. Accept the risk on behalf of human resources
- D. Assess only network encryption

Question 6 (CISM4-033)

Scenario: An arena plans facial recognition for entry. The pilot considers match accuracy but not template theft, demographic performance variation, provider retention, or the inability to reissue a compromised biometric.

What is the PRIMARY assessment deficiency?

- A. The pilot did not measure ticket-sale volume
- B. The technology should be rated low risk because it is automated
- C. The assessment should consider accuracy as the only relevant control
- D. Material privacy, security, fairness, lifecycle, and third-party scenarios were omitted

Question 7 (CISM4-034)

Why should a quantitative risk estimate include sensitivity analysis?

- A. It guarantees the forecast will equal the realized loss
- B. It shows which assumptions and inputs most influence the result
- C. It converts every technical score into currency
- D. It replaces the need for business judgment

Question 8 (CISM4-035)

Scenario: A distributor values an order system at \$600,000. A disruption would affect 30% of that value and is expected 0.5 times per year.

What is the annualized loss expectancy?

- A. \$30,000
- B. \$300,000
- C. \$180,000
- D. \$90,000

Question 9 (CISM4-036)

Scenario: A pharmacy identifies active credential attacks, weak password-reset verification, and potential exposure of prescription histories.

How should these elements be classified?

- A. Credential attacks are the vulnerability, weak verification is the impact, and disclosure is the threat
- B. Credential attacks are the threat, weak verification is the vulnerability, and disclosure is the impact
- C. All three are controls
- D. Credential attacks are the impact, weak verification is the threat, and disclosure is the vulnerability

Question 10 (CISM4-037)

Scenario: A risk register records only a low score after endpoint controls, without documenting the uncontrolled exposure or evidence that the controls operate effectively.

What should be added FIRST?

- A. A statement that compliance guarantees low risk
- B. A planned-control score presented as current exposure
- C. Only the number of installed agents
- D. The inherent scenario, current control evidence, residual assessment, assumptions, and owner

Question 11 (CISM4-038)

Scenario: Four unrelated accounting vendors all use one document-delivery network. Each vendor passed review, but the shared network has had repeated outages and no tested alternate route.

Which finding is MOST important?

- A. A shared fourth party can cause correlated interruption across all vendors
- B. The vendors use different invoice formats
- C. Every vendor should receive the same technical score
- D. Outsourcing eliminates internal accountability

Question 12 (CISM4-039)

Scenario: A manufacturer has two equal-scored risks. One may briefly delay expense reporting; the other may corrupt maintenance instructions used during a plant shutdown next week.

Which risk should be prioritized?

- A. Expense reporting because financial systems always rank first
- B. Neither because equal scores prevent prioritization
- C. Whichever system has more vulnerabilities
- D. Maintenance instructions because imminent safety and operational consequences add material context

Question 13 (CISM4-040)

Scenario: A risk register lists ratings but omits owners, assessment dates, assumptions, and review triggers.

What is the PRIMARY consequence?

- A. Decisions cannot be reliably assigned, reproduced, or revisited when conditions change
- B. The register will contain too few technical findings
- C. Every listed risk becomes inherent risk
- D. Risk acceptance transfers automatically to security

Question 14 (CISM4-041)

Scenario: Three divisions rate dependence on a central certificate service as low within local tolerance. A single failure would stop all digital sales and exceed enterprise appetite.

What is the BEST assessment action?

- A. Average the three low ratings
- B. Delete all local entries
- C. Report the enterprise concentration scenario while preserving local ownership records
- D. Ignore enterprise appetite because each division is within tolerance

Question 15 (CISM4-042)

Scenario: Executives must decide whether to enter a market that requires reliance on one identity provider. Frequency data is limited, and the security team has produced only technical severity scores.

What should the information security manager present?

- A. A single exact loss value
- B. Business scenarios, plausible impact ranges, assumptions, concentration exposure, and response options
- C. A recommendation to wait for an actual outage
- D. Only the highest technical score

Question 16 (CISM4-043)

Which action BEST represents risk avoidance?

- A. Formally retaining residual exposure
- B. Insuring specified loss costs
- C. Reducing likelihood with a control
- D. Discontinuing the activity that creates the exposure

Question 17 (CISM4-044)

Who should decide whether residual risk is accepted?

- A. The assessor who assigned the rating
- B. The control operator
- C. The designated business risk owner with policy-defined authority
- D. The external auditor

Question 18 (CISM4-045)

Scenario: A concert promoter buys insurance for breach-notification expenses. Ticketing outages, reputation damage, exclusions, and customer obligations remain with the promoter.

How should the response be described?

- A. Complete avoidance
- B. Elimination of impact
- C. Transfer of financial loss while exposure remains.
- D. Acceptance of every consequence

Question 19 (CISM4-046)

Scenario: A health service must encrypt a regulated data set. A cheaper control reduces unauthorized access but does not satisfy the binding encryption obligation. A compliant control reduces risk within tolerance at higher cost.

What should be recommended?

- A. The compliant control meeting mandatory obligations and acceptable residual risk.
- B. The cheaper control because cost always governs treatment
- C. Risk acceptance by the system administrator
- D. Insurance instead of compliance

Question 20 (CISM4-047)

Scenario: A farm cooperative has a low residual website risk within tolerance. Further treatment costs more than the plausible impact, and the owner has appropriate authority.

What is the BEST response?

- A. Eliminate the website
- B. Record acceptance with rationale, assumptions, conditions, and review date.
- C. Have security accept it informally
- D. Remove it from the register

Question 21 (CISM4-048)

Scenario: A mobile banking feature has an above-tolerance fraud risk. The project records a future control but assigns no owner, funding, or release criterion.

What is the BEST corrective action?

- A. Assign and fund treatment, requiring residual-risk evidence at release.
- B. Ask developers to accept the risk
- C. Move the issue to a post-release backlog
- D. Lower the rating to protect the schedule

Question 22 (CISM4-049)

Scenario: An online broker wants an early warning that automated account attacks are increasing.

Which measure is the BEST key risk indicator?

- A. Training courses completed
- B. Rate of credible automated login attacks.
- C. Policies reviewed
- D. Security budget spent

Question 23 (CISM4-050)

Scenario: A university learns after contract signature that a learning provider subcontracts student analytics without approval. Security review occurs only during implementation.

Which process change is MOST effective?

- A. Review all contracts after launch
- B. Prohibit every subcontractor
- C. Require risk-tiered data-use and subcontractor review before contracting.
- D. Let procurement accept all information risk

Question 24 (CISM4-051)

Scenario: A laboratory cannot install the standard agent on certified equipment. It proposes isolation and log review, but testing shows the isolation rule permits an undocumented management path.

What should the information security manager do FIRST?

- A. Reassess control coverage and residual risk before seeking authorized exception approval
- B. Accept risk for the laboratory
- C. Ignore the path because it is for management
- D. Approve because two compensating controls exist

Question 25 (CISM4-052)

Scenario: A temporary acceptance requires failed backup jobs to remain below 2%. The rate reaches 6% for two weeks, meeting the documented trigger.

What should happen NEXT?

- A. Wait for data loss
- B. Raise the threshold retroactively
- C. Invoke reassessment with the risk owner and consider revised treatment
- D. Close the risk because monitoring worked

Question 26 (CISM4-053)

Scenario: A card issuer's fraud-control detection rate has declined for five months, breached its trigger, and left residual risk above tolerance. The control owner has missed two recovery dates.

Which action is MOST appropriate?

- A. Wait for the annual review
- B. Escalate exposure and missed actions for owner review.
- C. Transfer ownership to analysts
- D. Lower the target

Question 27 (CISM4-054)

Scenario: A claims database was accepted for internal access with daily reconciliation. A change adds partner access and replaces reconciliation with monthly sampling.

What is the MOST appropriate action?

- A. Keep the prior acceptance
- B. Approve because the database is unchanged
- C. Let the partner accept the risk
- D. Reassess because exposure and a control assumption changed.

Question 28 (CISM4-055)

Scenario: A branch cannot meet a binding security obligation before launch. Its manager offers local acceptance, but policy provides no authority to waive the requirement.

What should the information security manager do?

- A. Coordinate compliant treatment with legal and authorized leadership.
- B. Accept the branch manager's signature
- C. Buy insurance and remove the obligation
- D. Hide the issue until audit

Question 29 (CISM4-056)

Scenario: An acquisition depends on an unsupported order system for four months. Immediate shutdown would stop sales. Segmentation and monitoring reduce risk to a temporarily approved tolerance while migration proceeds.

Which response is BEST?

- A. Accept indefinitely
- B. Shut down regardless of business impact
- C. Use temporary safeguards, authorized acceptance, monitoring, and a migration deadline.
- D. Rely on the seller's past operation

Question 30 (CISM4-057)

Scenario: Executives receive 200 overdue security tasks but cannot see whether supplier risk is rising or what action they must authorize.

How should reporting be improved?

- A. Add more raw tasks
- B. Show supplier risk trends, treatment, exceptions, and decisions.
- C. Report only realized losses
- D. Sort tasks by analyst

Answer Key

Domain II - Information Security Risk Management

1 D	2 C	3 B	4 A	5 A
6 D	7 B	8 D	9 B	10 D
11 A	12 D	13 A	14 C	15 B
16 D	17 C	18 C	19 A	20 B
21 A	22 B	23 C	24 A	25 C
26 B	27 D	28 A	29 C	30 B

Detailed Explanations

Question 1 (CISM4-028)

Correct answer: D - The risk an organization is willing to pursue or retain.

Risk appetite expresses the amount and type of risk the organization is willing to pursue or retain. Residual risk remains after controls, capacity is the maximum sustainable exposure, and a control threshold is an operational measure rather than appetite.

Question 2 (CISM4-029)

Correct answer: C - Validated consequences to dependent business processes and objectives

Impact should reflect validated consequences to business processes and objectives. Vulnerability counts concern exploitable conditions, purchase price rarely captures operational value, and tool preference does not establish business harm.

Question 3 (CISM4-030)

Correct answer: B - The exposure exceeds risk capacity and requires redesign, limitation, or another viable response

Appetite cannot exceed the organization's practical capacity to absorb loss. The service must be redesigned, limited, or otherwise treated; changing an estimate does not create capital, and waiting for a loss would ignore a threat to viability.

Question 4 (CISM4-031)

Correct answer: A - The safety and regulatory consequences of corrupted historical data

The archive's integrity affects safety and regulatory decisions, which should drive impact. Storage cost, file count, and absence of real-time control do not capture the consequences of corrupted evidence.

Question 5 (CISM4-032)

Correct answer: A - Reassess jurisdiction, data flow, obligations, access, and business impact

The new location, recipients, and data flow change external context and possibly obligations, regardless of unchanged technical controls. The prior rating may no longer apply, security should not accept the business risk, and encryption alone does not cover the change.

Question 6 (CISM4-033)

Correct answer: D - Material privacy, security, fairness, lifecycle, and third-party scenarios were omitted

A biometric assessment must address misuse, theft, performance effects, retention, irreversibility, and provider dependencies. Ticket volume is secondary, automation does not imply low risk, and accuracy alone cannot represent the full exposure.

Question 7 (CISM4-034)

Correct answer: B - It shows which assumptions and inputs most influence the result

Sensitivity analysis shows how changes in key inputs affect the estimate and highlights where evidence matters most. It cannot guarantee outcomes, replace judgment, or create a valid financial conversion from technical severity.

Question 8 (CISM4-035)**Correct answer: D - \$90,000**

Single loss expectancy is \$600,000 multiplied by 30%, or \$180,000. Multiplying by the annual rate of 0.5 gives an annualized loss expectancy of \$90,000. The other values omit or misapply a factor.

Question 9 (CISM4-036)**Correct answer: B - Credential attacks are the threat, weak verification is the vulnerability, and disclosure is the impact**

Credential attacks are threat activity, weak verification is an exploitable condition, and disclosure is a business consequence. The alternatives reverse distinct concepts or incorrectly treat them as controls.

Question 10 (CISM4-037)**Correct answer: D - The inherent scenario, current control evidence, residual assessment, assumptions, and owner**

Decision-makers need the underlying scenario, exposure before controls, evidence of current control effect, remaining risk, assumptions, and ownership. Compliance, future controls, or installation counts alone do not establish effective risk reduction.

Question 11 (CISM4-038)**Correct answer: A - A shared fourth party can cause correlated interruption across all vendors**

The shared network creates concentration risk that individual vendor reviews may obscure. Invoice formats are not the central security issue, identical ratings are not justified automatically, and outsourcing does not remove accountability.

Question 12 (CISM4-039)**Correct answer: D - Maintenance instructions because imminent safety and operational consequences add material context**

The imminent shutdown and possible safety consequence make the maintenance scenario more urgent despite equal summary scores. Asset labels and vulnerability counts do not replace business context, and equal ratings need not imply equal priority.

Question 13 (CISM4-040)**Correct answer: A - Decisions cannot be reliably assigned, reproduced, or revisited when conditions change**

Without ownership, timing, assumptions, and triggers, the record cannot support accountability or meaningful reassessment. The issue is not technical volume, it does not change risk type, and ownership never transfers automatically.

Question 14 (CISM4-041)**Correct answer: C - Report the enterprise concentration scenario while preserving local ownership records**

The correlated enterprise impact must be reported separately while local records retain useful ownership detail. Deletion or averaging obscures exposure, and local tolerance does not override enterprise appetite.

Question 15 (CISM4-042)

Correct answer: B - Business scenarios, plausible impact ranges, assumptions, concentration exposure, and response options

Executives need scenario-based business consequences, transparent ranges and assumptions, concentration risk, and viable responses. A point value or technical score overstates or omits evidence, while waiting avoids the current decision.

Question 16 (CISM4-043)

Correct answer: D - Discontinuing the activity that creates the exposure

Avoidance removes the risk-producing activity. Insurance shares financial consequences, controls mitigate risk, and formal retention is acceptance.

Question 17 (CISM4-044)

Correct answer: C - The designated business risk owner with policy-defined authority

The authorized business risk owner decides acceptance. Assessors and auditors provide evidence, while control operators manage controls; none automatically owns the business consequence.

Question 18 (CISM4-045)

Correct answer: C - Transfer of financial loss while exposure remains.

Insurance transfers only covered financial consequences; operational, reputational, excluded, and accountability exposures remain. It is neither avoidance nor elimination, and purchasing coverage is more than simple acceptance.

Question 19 (CISM4-046)

Correct answer: A - The compliant control meeting mandatory obligations and acceptable residual risk.

The response must satisfy the binding obligation and reduce exposure to the approved level. Cost cannot override a mandatory duty, a system administrator lacks acceptance authority, and insurance does not replace compliance.

Question 20 (CISM4-047)

Correct answer: B - Record acceptance with rationale, assumptions, conditions, and review date.

Formal acceptance is proportionate when residual exposure is within tolerance and the authorized owner records its basis and review conditions. Avoidance is excessive, security should not accept informally, and accepted risk remains visible.

Question 21 (CISM4-048)

Correct answer: A - Assign and fund treatment, requiring residual-risk evidence at release.

Ownership, funding, and a release criterion integrate treatment into the project decision. A later backlog leaves current exposure unresolved, developers may lack business authority, and changing a rating does not reduce risk.

Question 22 (CISM4-049)

Correct answer: B - Rate of credible automated login attacks.

The attack rate directly signals changing threat exposure. Training, spending, and policy reviews measure activity, not the stated risk as directly.

Question 23 (CISM4-050)

Correct answer: C - Require risk-tiered data-use and subcontractor review before contracting.

Early risk-tiered review preserves leverage to select, negotiate, treat, or seek authorized acceptance. Postlaunch review is late, universal prohibition may be disproportionate, and procurement does not automatically own all business risk.

Question 24 (CISM4-051)

Correct answer: A - Reassess control coverage and residual risk before seeking authorized exception approval

The undocumented path undermines the proposed control, so coverage and residual risk require reassessment before an owner decides. Control count does not prove effectiveness, security should not accept for the business, and a management path can still be exploited.

Question 25 (CISM4-052)

Correct answer: C - Invoke reassessment with the risk owner and consider revised treatment

The agreed trigger requires timely reassessment and a new response decision. Raising it conceals exposure, waiting defeats a leading indicator, and effective monitoring does not close the underlying risk.

Question 26 (CISM4-053)

Correct answer: B - Escalate exposure and missed actions for owner review.

Persistent deterioration and missed actions require escalation to the accountable owner. Waiting or lowering targets hides the condition, and analysts operating a control do not inherit business-risk ownership.

Question 27 (CISM4-054)

Correct answer: D - Reassess because exposure and a control assumption changed.

External access and weaker reconciliation invalidate the prior assessment assumptions. The unchanged database does not preserve the old exposure, and a partner cannot accept the organization's business consequence.

Question 28 (CISM4-055)

Correct answer: A - Coordinate compliant treatment with legal and authorized leadership.

A mandatory duty cannot be waived through unauthorized local acceptance. Legal and accountable leadership must choose compliant treatment or change the launch; insurance and delayed disclosure do not remove the obligation.

Question 29 (CISM4-056)

Correct answer: C - Use temporary safeguards, authorized acceptance, monitoring, and a migration deadline.

A conditioned, monitored, time-bound transition supports the acquisition while controlling exposure within approved tolerance. Indefinite acceptance exceeds scope, immediate shutdown ignores the approved objective, and past operation is not treatment evidence.

Question 30 (CISM4-057)

Correct answer: B - Show supplier risk trends, treatment, exceptions, and decisions.

Executive reporting must connect material scenarios and trends to appetite, explain treatment performance and exceptions, and identify decisions. Raw task detail, realized losses alone, or analyst sorting does not provide the needed business context.